
Basara Attendance Build Brief

One application, built by the whole class. You will replace the paper attendance sheet that gets retyped into Excel every night — with a system that verifies you were in the room, that it was really you, and that answers questions in plain English.

THE CLASS

106 students · 19 groups

TRACKS

BE · FE · UI/UX · ML · SPD

SPRINT 1 ISSUED

31 July 2026

What We Are Building, and Why

Start with the problem. It is in this room.

THE PROBLEM

A paper sheet, and someone retyping it at night.

Attendance for this course is taken on paper. Student 1 to student n, filled in by hand, passed along the row. Someone on the team then sits in the evening and types all of it into an Excel sheet. It is slow, it is error-prone, and a sheet passed down a row is trivially easy to fill in for a friend who is not here.

WHAT WE BUILD INSTEAD

The class ships the tool that fixes the class.

You mark your own attendance from your own phone, from inside this room. The retyping disappears. Every one of you will have built the system that made it disappear — and that is a far better answer in an interview than any assignment.

The end state, in one sentence

A student opens a URL on their phone, marks attendance from inside the classroom, is **verified by their own face**, and staff ask the data a question **in plain English** and get a true answer back.

Three rules everything else hangs off

#	RULE	WHY IT IS NON-NEGOTIABLE
1	One mark per student per session	Enforced by a database constraint, not by an <code>if</code> statement. A check followed by a write is a race condition, and two taps on a slow connection will find it.
2	The client is never trusted	Anything a phone can set, a phone can lie about — coordinates, timestamps, the photo itself. The server decides. Every time.
3	Nothing leaves this server	Attendance photos and face embeddings stay on the class machine. Not S3, not a commercial cloud, not outside India. This one is a promise to your classmates.

What each of you walks away holding

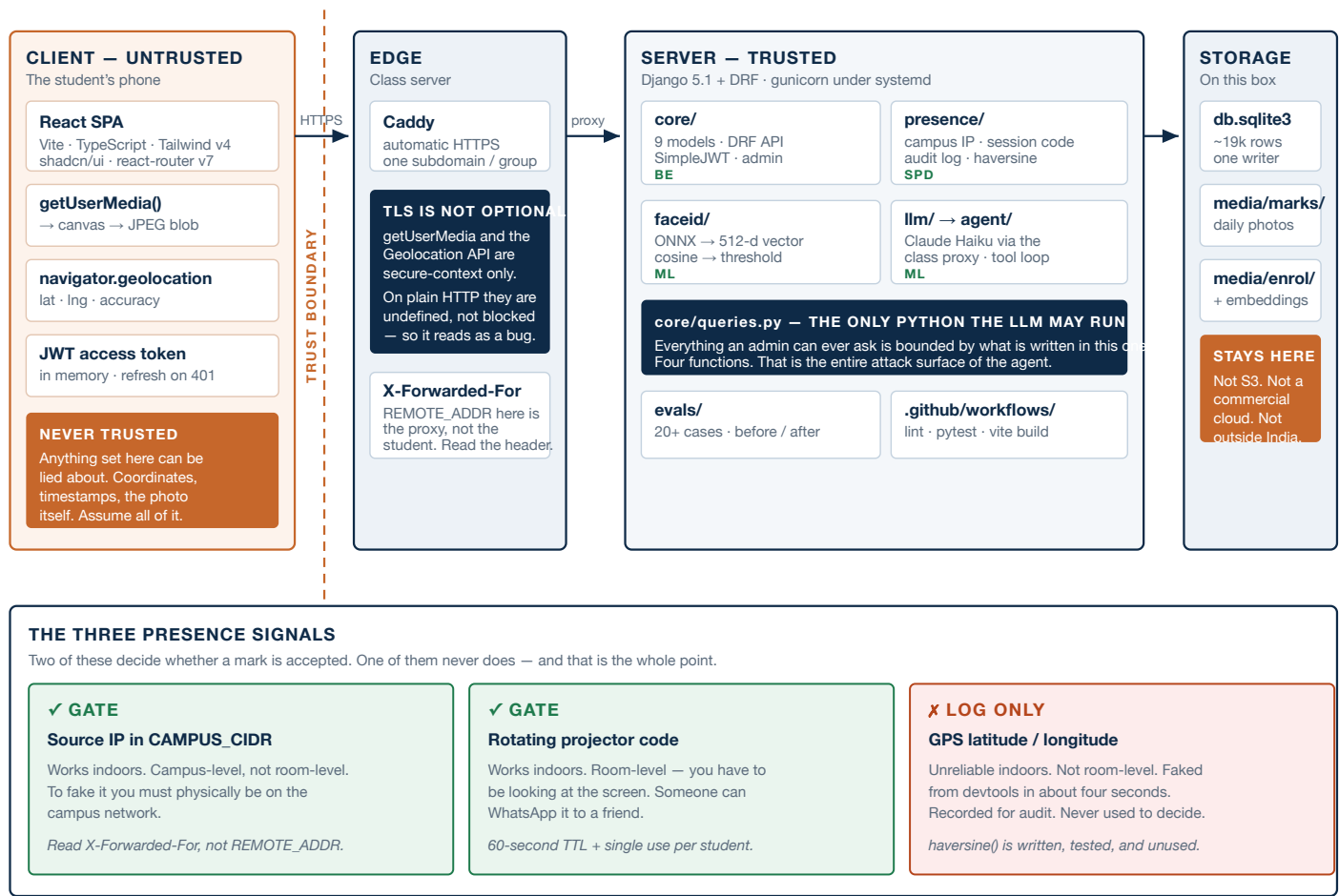
- A **live HTTPS URL** anyone can open on a phone
- A **branch and merged pull requests** with your name on them
- A **face-match threshold you chose** from measured data, and can defend
- A **presence check** you can explain *and* attack
- An **LLM feature** whose cost per call you can state in rupees
- Real experience of **code review** across nineteen teams

A note on the reference implementation

You have been given a **working production attendance system** to port from — the same stack, already deployed and in real use. It is genuinely useful, and it is also genuinely flawed: plaintext passwords, a login token that is generated and then never checked again, and every endpoint open to the world. Its own authors documented all of this. Most of you have never read production code before. You are about to read some, find the holes yourselves, and fix them. **Port from it. Do not copy it.**

Architecture

Where your track sits, and where the trust boundary falls.



Every box is owned by exactly one track, and every arrow is a contract between two groups. If you change what crosses an arrow, the group on the other side finds out from your pull request — not from a broken build.

Stack, Repo and Process

What we are using, why, and how the code moves.

The stack

LAYER	CHOICE	WHY THIS ONE
Frontend	Vite · React 18 · TypeScript · Tailwind v4 · shadcn/ui · react-router v7	The reference app is already on exactly this stack, so this is a port rather than a build from nothing.
Backend	Django 5.1 · Django REST Framework	Batteries included, and the nine models you need are already written.
Auth	JWT via <code>django-rest-framework-simplejwt</code>	Student ID and password. No second factor — the complexity budget is spent on faces and presence instead.
Database	SQLite	106 students × 5 subjects × ~36 sessions ≈ 19,000 rows. One writer, one machine. Postgres would add an install step per team and buy us nothing. This is a decision, not an oversight.
Face matching	ONNX Runtime · MobileFaceNet/ArcFace · 512-d	Runs locally, and — unlike a hosted vision API — returns a similarity score , which is what makes a threshold possible.
LLM	Claude Haiku via the class proxy	One shared key, spend visible to the instructor, no card needed by anyone.
Serving	Caddy · gunicorn · systemd	Automatic HTTPS with no certificate wrangling — and without HTTPS, the camera does not work at all.

Branches

```
main          protected  deploys to production
├─ staging      release candidates
├─ dev          integration — every pull request targets this
└─ team/<your-group>    e.g. team/femmeforce, team/grp5
```

Pull requests go `team/*` → `dev`, reviewed by **another group on your track**. Promotion to `staging` and `main` happens together, in class. **All nineteen branches already exist** — check yours out, do not create it. Your branch name is on the last page.

Today, before you leave the room

- 1 Clone the repository, then `git checkout team/<your-group-slug>`.
- 2 Find your track page in this brief. Read the architecture diagram opposite it.
- 3 Backend and ML: `python3.12 -m venv .venv && pip install -r requirements.txt`. **Python 3.12 or 3.13 — not 3.14**, which has no prebuilt wheels for numpy or onnxruntime.
Frontend and UI/UX: `npm install` inside `frontend/`, then `npm run dev`.
- 4 Make **one real commit** — the smallest item on your backlog. Not a README edit.
- 5 `git push origin team/<your-group-slug>` and open a **draft pull request** into `dev`. No push access yet? Fork it — the README shows both routes.

The backend runs, but it answers exactly one route

`core/urls.py` ships as a **stub** — enough for `runserver` to start and `/api/health/` to return `{"ok":true}`, and nothing more. **GRP12 writes the real URLconf**, and the other seven endpoints are listed in a comment at the top of that file. Nobody is blocked while they do it, but nothing else works until they have. If you are waiting, read `core/models.py` — nine models, already finished, and every track reads from them.

Repository: `<repo-url>` — written on the board.

Who Is Building What

Nineteen groups · 106 students · five tracks.

TRACK	OWNS	GROUPS	GROUPS	STUDENTS
BE	Backend	GRP5 (6) · GRP7 (5) · GRP12 (3) · GRP10 (10)	4	24
FE	Frontend	BALAJI (5) · DRAGONS (5) · GRP14 (4) · GRP8 (5)	4	19
UI/UX	UI / UX	MINIONS (5) · GRP6 (6) · ASTERIX (5)	3	16
ML	ML & AI	ANUSHA (6) · NEXAAI (5) · GRP4 (5) · FEMMEFORCE (8) · GRP11 (5)	5	29
SPD	Platform	BHUVANESHWARI (5) · MINIBYTES (8) · ROCKSTARS (5)	3	18

How these were assigned

Your track starts from the category your group chose. Then it was rebalanced, because self-selection produced **43 students on ML and 5 on frontend** — forty-three people cannot work on one feature, and five people cannot carry an entire frontend.

Groups that moved: **BALAJI** ML → FE · **DRAGONS** no category → FE · **GRP14** ML → FE · **GRP12** no category → BE · **GRP10** BE/ML → BE · **ASTERIX** no category → UI/UX. Groups shown in **bold** above are the ones that changed. ML still has the most groups, on purpose — it carries face recognition, the LLM ask path, the agent loop and evals.

Which directory belongs to which track

PATH	TRACK	WHAT LIVES THERE
basara-attendance/core/	BE	Models (already written), serializers, views, URLs, admin, migrations
basara-attendance/config/	BE	Settings, DRF + JWT config, CORS, root URLconf
frontend/src/app/	FE	Screens, routing, auth context, route guards
frontend/src/services/	FE	API client, token refresh, error handling
frontend/src/styles/	UI/UX	Design tokens, theme, dark mode
frontend/src/components/ui/	UI/UX	Shared primitives and the six extracted components
basara-attendance/faceid/	ML	ONNX embeddings, cosine, verify, threshold sweep
basara-attendance/llm/ agent/ evals/	ML	Claude client, the ask endpoint, agent loop, eval set
basara-attendance/core/queries.py	ML	The bounded query functions the agent is allowed to call
basara-attendance/presence/	SPD	Campus IP, session codes, audit log, haversine
deploy/ .github/workflows/	SPD	Caddy, systemd, CI, deployment

Your track is where you start, not a fence. If your group finishes its backlog, the next thing you do is review another group's pull request — that is real work, and it counts.

Django, DRF, JWT, and the data model everyone else depends on.

Your mission. You own the truth. Every other track reads what you write. If the API is wrong, the app is wrong no matter how good it looks.

GRP5 · 6

GRP7 · 5

GRP12 · 3

GRP10 · 10

You own: `core/` · `config/`

Sprint 1 — the backlog

DONE	TASK	WHAT IT MEANS
☐	Make it start at all	<code>config/urls.py</code> includes <code>core.urls</code> , which does not exist — <code>runserver</code> crashes today. Write it. First commit of the day; nobody can run anything until it lands.
☐	Wire up DRF and JWT	<code>pip install djangorestframework-simplejwt django-cors-headers</code> , then add the <code>REST_FRAMEWORK</code> , <code>SIMPLE_JWT</code> and <code>CORS</code> blocks to <code>config/settings.py</code> — there is no <code>REST_FRAMEWORK</code> block at all right now.
☐	Do not rewrite the models	<code>core/models.py</code> is finished: nine models, already carrying <code>photo</code> , <code>lat/lng/accuracy</code> , <code>face_score</code> and a <code>signals</code> JSON field. Read it, then run your first migration.
☐	Serializers, views, admin	<code>core/serializers.py</code> , <code>core/views.py</code> , <code>core/admin.py</code> . Register every model in admin — the reference app registers one out of ten, so you cannot inspect anything.
☐	The eight endpoints	<code>auth/login/</code> · <code>auth/refresh/</code> · <code>auth/me/</code> · <code>attendance/mark/</code> (multipart) · <code>attendance/today/</code> · <code>attendance/my-records/</code> · <code>admin/overview/?date=</code> · <code>health/</code>
☐	Marking rules	One mark per student per IST day → 409 . Block Sundays and <code>Holiday</code> rows. Wrap the write in <code>transaction.atomic()</code> , with a real <code>UniqueConstraint</code> behind it — a check-then-write is a race, not a constraint.
☐	Seed the database	A <code>seed_demo</code> management command with a fixed random seed , so every team's checkpoint number matches the one on the projector.

Who takes what

GROUP	FIRST PIECE OF WORK
GRP5	Auth: login, refresh, <code>/api/auth/me/</code> , permission classes
GRP7	The mark endpoint and every one of its rules
GRP10	Read endpoints, admin overview, Django admin, and the seed command
GRP12	<code>core/urls.py</code> first, then settings, CORS and migrations

Four defects in the reference app. Fix them; do not copy them.

`pmutwd_attendance/be` is real production code, and its auth is theatre. **(1)** Plaintext password comparison — use `django.contrib.auth`. **(2)** Login returns `str(uuid.uuid4())`, never stored, never checked — and the frontend sends it as a Bearer token forever. **(3)** All 27 endpoints `AllowAny`; no view reads `request.user`. **(4)** `attendance_datetime` comes from the client, so any past date can be backfilled.

Start here. That project's stakeholder asked for `GET /api/auth/me`. Five lines of code — and **impossible to build there**, because the token meant nothing, so the server had no way to know who was asking. Auth is architecture, not a feature you add later.

Done looks like: `curl -s localhost:8000/api/health/` returns `{"ok":true}`, and a `POST /api/attendance/mark/` without a valid token returns **401**, not 201.

React, the router, and the two browser APIs this whole app rests on.

Your mission. You own what a student actually touches. A phone, one thumb, thirty seconds before class starts. If marking attendance takes longer than the paper sheet, we have built nothing.

- BALAJI · 5
- DRAGONS · 5
- GRP14 · 4
- GRP8 · 5

You own: frontend/src/app/ · frontend/src/services/

Sprint 1 — the backlog

DONE	TASK	WHAT IT MEANS
☐	Scaffold it	Vite + React 18 + TypeScript + Tailwind v4 + shadcn + react-router v7 in frontend/. Set VITE_API_BASE_URL and the @ → ./src alias.
☐	Add the tsconfig.json	The reference repo ships .tsx files with no tsconfig.json and TypeScript not installed — esbuild strips the types and checks nothing. Do not inherit that.
☐	The API layer	services/api.ts : fetch wrapper, Authorization: Bearer , and the 401 → refresh → retry interceptor the reference never had.
☐	Auth plumbing	context/AuthContext.tsx and ProtectedRoute.tsx . Port them, then fix the dangling redirect at ProtectedRoute.tsx:16 which sends users to a route that does not exist.
☐	Four screens	Login · MarkAttendance · MyRecords · AdminDashboard .
☐	Camera and geolocation	Port fe/src/app/components/employee/MarkAttendance.tsx:224–332 and nothing else from that file — it is 1,285 lines and about 110 of them matter.
☐	The admin pie chart	recharts donut, matching ManagerDashboard.tsx:214–218 : present / leave / not-marked, with a live count beside each slice.

Who takes what

GROUP	FIRST PIECE OF WORK
GRP8	Scaffold, routing, services/api.ts and the refresh interceptor
BALAJI	MarkAttendance — camera, canvas, capture, retake
GRP14	Login and MyRecords
DRAGONS	AdminDashboard and the recharts donut

Two patterns in that file were earned the hard way. Keep both.

(1) The stream is attached to the video element in a useEffect (:75–80), not inside startCamera() — because the <video> element has not mounted yet when the stream arrives. (2) Geolocation tries high accuracy, and on failure retries with enableHighAccuracy:false (:319–331). Also keep both artefacts of capture: a dataURL for the on-screen preview and a File for the upload.

You will hit this on Day 4, and it will look like your bug. getUserMedia() and the Geolocation API only work in a secure context. Over plain HTTP navigator.mediaDevices is not blocked — it is undefined , so you get a TypeError that reads exactly like an application error. localhost counts as secure. http://<server-ip> does not.

Done looks like: On a real phone, over HTTPS: camera opens, photo captures, coordinates appear, submit returns 201, and a second submit the same day returns 409 with a message a human can read.

The design system, and making the components actually use it.

Your mission. You own how it feels and whether it holds together. Not decoration — a shared vocabulary that stops four frontend groups from inventing four different buttons.

MINIONS · 5

GRP6 · 6

ASTERIX · 5

You own: `frontend/src/styles/` · `frontend/src/components/ui/`

Sprint 1 — the backlog

DONE	TASK	WHAT IT MEANS
☐	Design tokens	<code>theme.css</code> using the Tailwind v4 <code>@theme inline</code> pattern from <code>pmutwd_attendance/fe/src/styles/theme.css</code> . Pick a Basar palette — do not just copy theirs.
☐	Bind components to tokens	Install only the shadcn primitives that get used, and make them read from the tokens. A token nobody references is a comment.
☐	Build the six shared components	<code>AppHeader</code> · <code>PhotoModal</code> · <code>MonthCalendar</code> + <code>legend</code> · <code>AttendanceRow</code> · <code>StatCard</code> · <code>EmptyState</code> . Every one of these is copy-pasted two or three times in the reference app.
☐	Status colour semantics	Decide once, write it down, and hand it to FE: present / absent / leave / holiday / today. Five states, five colours, one source of truth.
☐	Mobile first	This gets used standing up, on a phone, in a classroom, in five minutes. Design that, then let the desktop fall out of it.
☐	Dark mode	Via the <code>.dark</code> token block. It costs almost nothing if tokens are done properly — and it is the test of whether they are.

Who takes what

GROUP	FIRST PIECE OF WORK
MINIONS	Tokens, palette, typography scale, dark mode
GRP6	The six shared components
ASTERIX	Mobile layouts, status colour semantics, and the written handoff to FE

The cautionary tale is sitting in the reference repo.

It vendors **49** shadcn components. App code imports **6** — all from a single screen. The three main screens ignore the design system entirely and hardcode Tailwind utility strings, and each one re-implements its own `<header>` inline. There is a full 353-line themed chart wrapper that nothing imports, and a `--custom-blue` token no component references. **A design system that nothing uses is not a design system.** Your job is the binding, not the library.

Design the failure states too. No camera permission. No GPS fix. Offline. Already marked today. Marked outside class hours. Those five screens are most of what a real user will actually see, and they are the ones nobody remembers to design.

Done looks like: Change one token value in `theme.css` and watch the colour move on all four screens. If you have to edit a component to change a colour, you are not done.

Face embeddings, thresholds, the LLM ask path, and evals.

Your mission. You own the parts that can be wrong in ways nobody notices. A threshold is a product decision wearing a number's clothes, and an agent that answers confidently and incorrectly is worse than no agent.

ANUSHA · 6

NEXAAI · 5

GRP4 · 5

FEMMEFORCE · 8

GRP11 · 5

You own: `faceid/` · `llm/` · `agent/` · `evals/` · `analysis/` · `core/queries.py`

Sprint 1 — the backlog

DONE	TASK	WHAT IT MEANS
☐	Embeddings	<code>faceid/embed.py</code> : ONNX detector + MobileFaceNet/ArcFace → 512-d vector. Three pure wheels, no C++ compiler. Then <code>cosine(a, b)</code> .
☐	Verification	<code>verify(roll_no, image_bytes) -> float</code> — best cosine similarity against that student's enrolled vectors. <code>EnrolmentPhoto.vector()</code> already exists in the model; use it.
☐	Threshold sweep	<code>faceid/sweep.py</code> — sweep the threshold across enrolled photos, plot false-accept and false-reject. Each group picks its own number and defends it out loud.
☐	Liveness, and its limits	Two frames 800 ms apart; reject if byte-identical or cosine ≈ 1.000 . Then hold a photo of a face up to the camera and watch it pass anyway.
☐	Query functions	<code>core/queries.py</code> : <code>attendance_percentage()</code> (worked example), <code>students_below_threshold()</code> , <code>attendance_by_subject()</code> , and one more. <code>pytest tests/test_queries.py</code> → 4 passed.
☐	The LLM ask	<code>llm/client.py</code> → class proxy, <code>claude-haiku-4-5-20251001</code> . <code>POST /api/ask/</code> returns schema-valid JSON. Then <code>agent/loop.py</code> , hand-written.
☐	Evals	<code>evals/run.py</code> — at least 20 cases, a before-score and an after-score, and one paragraph on what changed between them.

Who takes what

GROUP	FIRST PIECE OF WORK
ANUSHA	<code>embed.py</code> , <code>cosine()</code> , the ONNX pipeline
NEXAAI	<code>verify()</code> and enrolment
GRP4	Threshold sweep, FAR/FRR curve, liveness
FEMMEFORCE	<code>core/queries.py</code> and pandas analysis
GRP11	<code>llm/client.py</code> , <code>/api/ask/</code> , agent loop, evals

Why not just send the photo to a vision API?

Two independent reasons. Anthropic's usage policy prohibits facial recognition. And decisively for this course: **a vision API cannot return a similarity score**. No score means no threshold, no false-accept / false-reject trade-off — and that trade-off is the entire lesson. So: local ONNX, on our own box.

The sentence we are aiming at: *"I chose 0.62 because a false reject costs a student their exam eligibility, and a false accept costs the institution very little."* Say that and you have stopped being someone who writes code. Also note: `core/queries.py` is the **only** Python the LLM will ever be allowed to run. Everything an admin can ask is bounded by what you write there.

Done looks like: Your own face → 200. Your partner's face → 403. And you can state your threshold and both of its error rates without looking them up.

Presence signals, HTTPS, deployment, CI/CD, and the audit trail.

Your mission. You own whether any of this can be believed. Attendance nobody can trust is a spreadsheet with extra steps — and an app that is down at 5pm is worth nothing at all.

BHUVANESHWARI · 5

MINIBYTES · 8

ROCKSTARS · 5

You own: `presence/` · `deploy/` · `.github/workflows/`

Sprint 1 — the backlog

DONE	TASK	WHAT IT MEANS
☐	Campus IP check	<code>check_campus_ip(request)</code> against <code>CAMPUS_CIDR</code> . Read X-Forwarded-For , not REMOTE_ADDR — behind a reverse proxy, <code>REMOTE_ADDR</code> is the proxy.
☐	Rotating projector code	<code>verify_session_code(code, student)</code> . 60-second TTL, and <code>CodeRedemption</code> makes it single-use per student. You have to be looking at the screen.
☐	<code>haversine()</code> , unused on purpose	Write it. Test it. Log the distance. Never gate on it. Be ready to explain that to someone who thinks it is a bug.
☐	Audit log	Write an <code>AuditLog</code> row on every attempt — accepted or rejected — with the reason. The rejections are the interesting half.
☐	HTTPS	Caddy with automatic TLS, one subdomain per group. Without this the camera and GPS simply do not work, so this blocks two other tracks.
☐	Keep it running	A systemd unit, <code>.env</code> handling, and <code>verify.sh</code> . It has to come back up after <code>sudo reboot</code> without you touching it.
☐	CI/CD	GitHub Actions: <code>lint</code> + <code>pytest</code> + <code>vite build</code> on every PR into <code>dev</code> ; deploy on <code>main</code> .

Who takes what

GROUP	FIRST PIECE OF WORK
BHUVANESHWARI	<code>presence/signals.py</code> — IP check, session codes, <code>haversine</code>
MINIBYTES	Caddy, TLS, systemd, <code>.env</code> , <code>verify.sh</code>
ROCKSTARS	GitHub Actions, branch protection, audit log, secret scanning

Two gates and one log. Know which is which.

Campus IP — works indoors, campus-level only, and you must physically be on the network. **Gate on it.** **Projector code** — works indoors, room-level, and someone can WhatsApp it; the 60-second TTL and single use are what make that survivable. **Gate on it.** **GPS** — unreliable indoors, not room-level, and trivially faked from devtools in about four seconds. **Log it and never gate on it.** Spoofed coordinates should still return 200, and you should be able to say why.

The reference deploy pipeline is the anti-pattern. `deploy-backend.yml` is `git pull && migrate && restart gunicorn` over SSH, against a live box with the SQLite file sitting in the working tree. No tests, no backup, no rollback. Improve on it, and write down why in the PR description. Also: `git log -p --all | grep -c "sk-ant"` must return 0.

Done looks like: The projector code returns 200. The same code 90 seconds later returns 403. Spoofed coordinates still return 200 — and you can explain that to the room. Then `sudo reboot`, and 60 seconds later the URL is up.

Teams and Branches

Nineteen groups · 106 students. Find your group, then your track page.

GROUP	TRACK	YOUR BRANCH	MEMBERS
GRP5	BE	team/grp5	6
GRP7	BE	team/grp7	5
GRP12	BE	team/grp12	3
GRP10	BE	team/grp10	10
BALAJI	FE	team/balaji	5
DRAGONS	FE	team/dragons	5
GRP14	FE	team/grp14	4
GRP8	FE	team/grp8	5
MINIONS	UI/UX	team/minions	5
GRP6	UI/UX	team/grp6	6
ASTERIX	UI/UX	team/asterix	5
ANUSHA	ML	team/anusha	6
NEXAAI	ML	team/nexaai	5
GRP4	ML	team/grp4	5
FEMMEFORCE	ML	team/femmeforce	8
GRP11	ML	team/grp11	5
BHUVANESHWARI	SPD	team/bhuvaneshwari	5
MINIBYTES	SPD	team/minibytes	8
ROCKSTARS	SPD	team/rockstars	5

Why there are no names in this document

This copy lives in a **public** repository, which search engines index and which is effectively permanent. Student names and group email addresses do not belong in it. The printed copy handed out in class carries the full roster; this one carries what you need to do the work and nothing else. **Apply the same rule to everything you commit** — attendance photos, face embeddings and the database are all in `.gitignore` for exactly this reason. Check before you `git add`.

Not sure which group you are in? Ask in class — the full roster is on the printed brief.